

Junior

1. Znalezienie oświadczenia lustracyjnego. Użycie **filetype:pdf "tajne"** , przeszukanie google , znajduje się na drugiej stronie w wyszukiwarce.

https://ko-gorzow.edu.pl/wp-content/uploads/2009/11/318905361_8454059.pdf

2. Znalezienie dokumentu pdf do użytku wewnętrznego. Użycie operatora **filetype:pdf "do użytku wewnętrznego"** , przeszukanie google. Pierwsza strona wyszukiawarki

<https://www.almirall.com/documents/4257831/5480307/TandC+PL.pdf/40301257-9816-3383-173c-279a480444fa>

3. Znalezienie katalogu sieciowego NASA. Użycie **intitle:"index of" inurl:ftp** , druga strona przeglądarki

<https://genesis.jpl.nasa.gov/ftp/>

4. Znalezienie katalogu sieciowego biblioteki online. Użycie operatora **intitle:"index of" "database.sql"**

<http://ibiblio.org/pub/linux/apps/database/sql/>

5. Znalezienie narzędzia do wyszukiwania paneli logowania administratora. Użycie operatora **intitle "admin panel"**

https://github.com/MK-Ware/admin-panel-finder/blob/master/admin_login.txt

MEDIUM

1. Użyłem programu **Exiftool** na linuxie .
2. Model telefonu, data wykonania , Oprogramowanie , czy zdjęcie było wykonane z flashem, że zdjęcie było wykonane tylnym aparatem, położenie GPS

3. Jak atakujący wykorzystują metadane do profilowania:

Geolokalizacja GPS ujawnia:

- Gdzie mieszkasz (zdjęcia z domu = dokładny adres)
- Gdzie pracujesz (zdjęcia w biurze)
- Twoje nawyki (regularnie odwiedzane miejsca)
- Gdzie jesteś TERAZ (zdjęcie na żywo = fizyczna lokalizacja w czasie rzeczywistym)

Model urządzenia + serial number pokazuje:

- Czy jesteś zamożny (iPhone = drogie urządzenie)
- Które zdjęcia zrobiłeś TY (ten sam serial = ten sam aparat)
- Można cię śledzić między różnymi kontami/platformami

Data i godzina ujawnia:

- Twój rozkład dnia (kiedy śpisz, pracujesz, jesteś poza domem)
- Strefy czasowe (gdzie podróżujesz)
- Najlepszy moment na atak (gdy jesteś nieobecny)

Software/Historia edycji wskazuje:

- Jakich programów używasz (potencjalne exploity)
- Twoje umiejętności techniczne
- Czy fałszujesz zdjęcia

Praktyczny scenariusz ataku: Stalker zbiera Twoje zdjęcia z Instagrama, ekstrahuje GPS, mapuje Twoją rutynę (dom → praca → siłownia), wie kiedy jesteś poza domem = **idealny moment na włamanie** lub **fizyczny atak**. Seryjny numer iPhone potwierdza, że wszystkie zdjęcia pochodzą od tej samej osoby, nawet z różnych kont.

Dlatego Facebook/Instagram/WhatsApp automatycznie usuwają metadane GPS przed publikacją - to ochrona przed stalkingiem i doxingiem.

Senior

1. Niezabezpieczona kamera - zapytanie : `http.title:"IP Camera" has_screenshot:true -honeypot`
2. Niezabezpieczona kamera - zapytanie : `"Server: Hikvision-Webs" port:80`
3. Panel sterowania SCADA - zapytanie : **"Siemens, SIMATIC" port:102"**
4. Protokół przemysłowy Modbus - zapytanie : `port:502 country:"PL"`
5. MongoDB - zapytanie : `"MongoDB Server Information" port:27017 -authentication`
6. Elasticsearch - zapytanie : `port:9200 "elastic indices"`

DLACZEGO TO NIEBEZPIECZNE?

Wystawienie niezabezpieczonych usług bezpośrednio do publicznej sieci jest skrajnie niebezpieczne z kilku powodów:

1. Bezpośredni dostęp do danych krytycznych Otwarte bazy danych (MongoDB, Elasticsearch, Redis) bez uwierzytelniania umożliwiają każdemu w internecie pełny dostęp do danych firmowych, osobowych klientów, haseł, transakcji finansowych czy tajemnic handlowych. Atakujący może je wykraść, zmodyfikować lub całkowicie usunąć, co prowadzi do naruszenia RODO, strat finansowych i utraty reputacji firmy.

2. Możliwość ataków na infrastrukturę krytyczną Niezabezpieczone systemy SCADA kontrolują instalacje przemysłowe - elektrownie, oczyszczalnie wody, linie produkcyjne. Dostęp do nich pozwala atakującemu na sabotaż, wywołanie awarii, zatrzymanie produkcji lub nawet zagrożenie życia ludzi. Kamery IP ujawniają wrażliwe lokalizacje, rozkład pomieszczeń i mogą służyć do rozpoznania przed fizycznym włamaniem.

3. Platforma do dalszych ataków Przejęte systemy mogą być wykorzystane jako botnet do ataków DDoS, proxy dla nielegalnych działań, hosting malware lub punkt wejścia do reszty sieci firmowej (lateral movement). Atakujący może zaszyfrować dane i zażądać okupu (ransomware), wykraść zasoby obliczeniowe do minowania kryptowalut lub sprzedać dostęp innym cyberprzestępcom w darknecie.